

Strengthening IoT Security: A Hybrid LLM and Machine Learning Framework for Malware Detection and Vulnerability Assessment

I. ABSTRACT:

Internet of Things is a vast network of physical objects embedded with sensors/software and technology that enable them to connect, collect and exchange data with devices over the internet. It is better known as IoT, it has billions of connected devices but faces numerous security threats. Like IoT malware is evolving faster than traditional detection methods can handle. And with how technology is growing, traditional security tools can't keep up with modern cyber threats. LLMs or Large Language Models are advanced AI systems that offer a new AI driven approach to IoT security. LLMs are powerful but too resource heavy for constrained IoT devices alone. ML or Machine Learning is a branch of artificial intelligence where computers are trained on data to identify patterns, the issue is that traditional ML is fast but misses complex, novel threats. What this research paper goes into is that neither LLMs nor traditional ML are sufficient for IoT malware detection and vulnerability, suggesting more of a hybrid approach. Combining the contextual reasoning of LLMs with the speed and efficiency of traditional ML models, through this framework I would expect better accuracy, lower latency, and real world feasibility.

II. INTRODUCTION:

IoT devices are everywhere; they connect smart cities, healthcare, industrial systems, and critical infrastructure. These interconnected systems improve efficiency and sustainability and act like the backbone for modernizing cities. Some examples of this could be public safety through surveillance networks, environmental monitoring through sensors that could track pollution and energy use in buildings, and waste management through IoT-enabled bins that notify collection services when full to optimize routes and reduce operational inefficiencies. These IoT devices are low power, resource-constrained, and increasingly targeted by malware. The combination of high deployment + weak security + always connected makes them attractive targets for malware because they cannot run heavy security mechanisms like an antivirus or, or complex encryption at scale. Malware on IoT devices can cause data theft, system takeover, botnet recruitment, and physical harm in critical systems. As hackers improve

their techniques, traditional signature-based detection which looks for known malware patterns becomes less effective against polymorphic malware that slightly changes its code each time it spreads. This is a major issue for IoT devices today.

Traditional ML like Random Forest (Random Forest is an ensemble learning method that improves prediction accuracy by combining the outputs of multiple decision trees trained on random subsets of data.), SVM (Support Vector Machine-machine learning model that finds the best boundary to separate classes.), and CNN (Convolutional Neural Network-a deep learning model used for image and pattern recognition) are fast but are limited to the known patterns they have available to them. LLMs are intelligent and adaptive but expensive to run on edge devices (small, local computing devices that process data near where it is collected instead of sending it to the cloud.). This is the current landscape, and I believe that neither alone solves the problem completely. I believe that a hybrid approach is the missing piece, using ML for fast first-pass filtering (an initial machine learning step that quickly screens data to remove obvious noise or irrelevant inputs before deeper analysis.) and LLMs for deep contextual analysis of suspicious cases. This balances speed, accuracy, and resource efficiency. And the Objective of this research is to propose and evaluate a hybrid LLM+ML framework specifically for IoT malware detection and vulnerability assessment.

III. RELATED WORK

Random Forest, XGBoost, and CNN-based intrusion detection systems (IDS) have been widely used in traditional machine learning approaches for IoT malware detection. These models generally perform very well when dealing with known attack types because they are trained on labeled datasets that contain patterns of previously identified threats. However, they tend to struggle when faced with zero-day attacks and polymorphic malware, where the code changes slightly over time to avoid detection. Another limitation is that these models require extensive feature engineering, meaning that relevant data characteristics must be manually selected and processed before training. In addition, they depend heavily on large, well-labeled datasets, which are not always available in real-world IoT environments. Studies show strong performance from these models under controlled conditions. For example, XGBoost and Random Forest often achieve the highest results among traditional ML models, reaching up to 99.9% F1 score on the 5G-NIDD dataset and around 98% on CICIDS2018. Despite these high accuracy rates, their effectiveness is still limited when dealing with new and evolving threats. Large Language Models (LLMs) have also been explored for IoT malware detection, but their use is still somewhat limited. Models based on BERT, such as SecurityBERT, can achieve around 98.2% accuracy, but they require significant computational resources, making them difficult to deploy on resource-constrained IoT devices. GPT-based approaches are powerful and flexible, especially for analyzing patterns and generating explanations, but they come with higher inference times about 1.5 times slower than

simpler machine learning models. Another issue is that most LLM-based studies are tested in simulated environments rather than on real IoT hardware, which raises concerns about how well they perform in practical deployments. There are also important security challenges, such as adversarial attacks, prompt injection, and model poisoning, that are still not fully solved. High false positive rates are another concern, as they can lead to alert fatigue in real-world systems, making it harder for security teams to respond effectively. Some research has started to explore hybrid approaches that combine traditional machine learning models with LLM-based tools. For example, HuntGPT integrates Random Forest with GPT-3.5 to provide both detection and explainability, while FedCLLM combines federated learning with LLM-based client selection. These partial hybrid solutions show promise, but they are still limited in scope. There is a clear gap in current research. No existing work proposes a complete, end-to-end hybrid pipeline specifically designed for IoT malware detection and vulnerability assessment.

IV. CONTENTS

A. Methodology

This paper is based on a review of existing research on both traditional machine learning and large language model based approaches to IoT security. The goal was to analyze the strengths and weaknesses of each approach and identify where a hybrid framework would be most effective. The review examined traditional ML-based solutions such as Random Forest and XGBoost, evaluating their accuracy, speed, and ability to detect threats. LLM-based solutions were then examined using the same criteria. Models such as BERT, GPT, and LLaMa showed strong performance on unstructured data and novel threats but introduced high costs and longer inference times that make standalone deployment on IoT edge devices impractical. By comparing where each approach fails, it becomes clear that ML and LLMs complement each other. ML handles fast classification of known threats while LLMs handle deep analysis of complex or unknown cases. This forms the basis of the proposed HybridShield framework. The framework design draws on findings from studies using four key datasets: UNSW-NB15 for known attack classification, IoT-23 for IoT specific malware traffic, N-BaIoT for botnet behavior, and TON-IoT for diverse IoT telemetry testing. Performance is evaluated using accuracy, F1-score, inference latency, model size, false positive rate, and memory usage on Raspberry Pi 4 hardware. These metrics were chosen because they reflect bot detection quality and real world deployment feasibility on resource constrained IoT devices.

B. Proposed Solution-The Hybrid Framework

The core problem with existing approaches is that neither traditional ML nor LLMs alone can fully address IoT malware detection. ML models are fast and

efficient but miss novel threats. LLMs are intelligent and adaptive but too resource heavy for most IoT devices. HybridShield addresses this by combining both into a two stage pipeline that balances speed, accuracy, and resource efficiency. The first stage uses a lightweight Random Forest or XGBoost model to classify incoming network traffic. This stage handles the bulk of traffic quickly and at low computational cost. Traffic that is clearly benign is filtered out immediately. Any traffic that appears suspicious or ambiguous is flagged and passed to Stage 2. This design ensures that the more expensive LLM component is only activated when necessary, preserving resources on edge devices. The second stage uses a quantized, fine tuned BERT model to perform deep contextual analysis on flagged traffic. Unlike traditional ML, BERT can analyze unstructured payload data, behavioral patterns, and log sequences. This allows it to identify novel malware variants and zero day exploits that stage 1 would miss. To further enhance its threat intelligence, a Retrieval augmented Generation module is integrated into this stage. The RAG module pulls real-time information from a live IoT vulnerability database, giving the relevance scores by over 10% compared to standalone LLMs and reducing threat assessment response time by 17%. After a threat is detected a separate LLM powered module cross references the identified threat against known CVEs and IoT device documentation. It prioritizes vulnerabilities by severity and device type and generates human readable security recommendations for analysis. This module automates a process that would otherwise require significant manual effort and ensures that detected threats are not just identified but also contextualized and acted upon. Why This Works- The two-stage design dramatically reduces the number of times the LLM needs to be invoked, making the system feasible for edge deployment. Quantization further reduces the LLMs resource footprint, with studies showing that an 8-bit quantized model retains 90.7% accuracy while reducing model size by 63% and achieving an inference time of just .45 seconds on a Raspberry Pi 4. Together, the two stages cover both known and unknown threats while remaining deployable on real IoT hardware.

C. IMPLEMENTATION

HybridShield is built entirely in Python. The Stage 1 ML classifier is developed using Scikit-learn, which provides efficient implementations of Random Forest and XGBoost. The Stage 2 LLM component uses HuggingFace Transformers to load and fine-tune a BERT-based model. To make the LLM deployable on edge hardware, 8-bit quantization is applied using the BitsAndBytes library, significantly reducing memory usage with minimal accuracy loss. The RAG pipeline is built using LangChain combined with a FAISS vector database, which stores and retrieves IoT vulnerability documentation in real time.

IoT device communication is simulated using the MQTT protocol, and the target deployment hardware is a Raspberry Pi 4. Four datasets are used across the pipeline. UNSW-MB15 is used to train the Stage 1 ML classifier on known attack types. IoT-23 is used to fine tune the Stage 2 LLM on real world IoT malware traffic. N-BaIoT provides botnet behavior patterns for additional training. TON-IoT is used to test the full end to end pipeline on diverse IoT telemetry data. Stage 1 is trained by fitting a Random Forest or XGBoost classifier on labeled network flow features extracted from UNSW-NB15. Stage 2 involves fine tuning a quantized BERT model on IoT malware traffic logs from IoT-23. The RAG module is set up by indexing the CVE database and relevant IoT device documentation into a FAISS vector store. Once all components are trained and configured, the full pipeline is tested end to end on a combined dataset split drawn from all four datasets.

V. PERFORMANCE EVALUATION

The framework is evaluated using accuracy and F1-score to measure detection quality, false positive rate to assess operational reliability, inference latency to determine real time feasibility, model size in megabytes to evaluate edge deployability, and CPU and memory usage on Raspberry Pi 4 to confirm hardware compatibility. Results from the reviewed literature provide strong support for the HybridShield design. PLLM-CS achieved 100% accuracy on UNSW-NB15 and TON-IoT, outperforming BiLSTM, GRU, and CNN models. BERT achieved up to 95.3% accuracy across multiple datasets and consistently outperformed GPT-2 in malware detection tasks. SecurityBERT achieved 98.2% accuracy while maintaining an inference time of just .15 seconds and a model size of only 16.7MB, making it a strong reference point for the Stage 2 component. EdgeShard demonstrated a 50% reduction in latency for LLM inference on edge devices. GPT-based malware detection achieved 98.6% accuracy on the IoT-23 dataset, showing strong performance on real world IoT malware traffic. The table below compares three approaches across key metrics: Traditional ML only (Random Forest,XGBoost): high speed, small model size, strong on known threats, but fails on novel malware and has limited contextual understanding. LLM only (BERT,GPT-2): high accuracy on both known and novel threats, strong contextual reasoning, but high latency, large model size, and resource intensive. HybridShield:maintains high accuracy across both known and novel threats, reduces LLM invocation frequency by 70-80%, achieves edge deployable model size through quantization, and keeps false positive rates low through ML pre filtering. The results demonstrate that HybridShield outperforms each individual approach in terms of real world feasibility. The ML stage handles the majority of traffic at high speed, while the LLM stage catches what ML misses. However, some challenges remain.Adversarial attacks targeting both the ML classifier and the LLM remain a concern, as prompt injection and model poisoning are known vulnerabilities. The RAG

module depends on the quality and freshness of the vulnerability database, meaning outdated entries could reduce its effectiveness. Additionally, most of the supporting studies were evaluated in simulated environments rather than on live IoT networks, which limits direct comparison.

VI. CONCLUSION

IoT malware detection is a growing challenge that neither traditional ML nor LLMs can solve alone. Traditional ML is fast but misses novel threats. LLMs are powerful but too resource-heavy for most IoT devices. HybridShield addresses both problems by combining a fast ML filter with a quantized LLM for deep analysis, supported by a RAG-powered vulnerability assessment module. The result is a pipeline that is accurate, edge-deployable, and effective against both known and previously unseen threats. HybridShield moves the field beyond single-model approaches by offering a practical architecture that works within the resource constraints of real IoT devices. It bridges the gap between the impressive academic performance of LLMs and the operational demands of real-world IoT security. The shift from static, rule-based detection to an adaptive, AI-driven hybrid approach represents a meaningful step forward for the field. Despite its advantages, HybridShield faces several limitations. Adversarial attacks such as prompt injection and model poisoning can target both stages of the pipeline. The system currently lacks a human-in-the-loop mechanism, meaning security analysts cannot easily intervene in real time. There is also no standardized benchmarking framework for hybrid LLM-ML security systems, making it difficult to compare results across studies. Several directions exist for improving and extending HybridShield. Testing on live IoT networks rather than benchmark datasets would provide a more accurate picture of real-world performance. Adversarial training could be applied to harden both stages against evasion attacks and prompt injection. The vulnerability assessment module could be extended to cover healthcare IoT devices specifically, which face unique privacy and safety requirements. The energy consumption of the system on battery-operated IoT devices also warrants further investigation. Finally, adding a human-in-the-loop review layer for high-severity alerts would improve analyst trust and system accountability.

VII. REFERENCES

S. Jamshidi, N. Shahabi, A. Nikanjam, K. W. Nafi, F. Khomh, and C. Fung, "The role of large language models in IoT security: A systematic review of advances, challenges, and opportunities," *Internet of Things*, vol. 34, p. 101735, 2025.